

データ取り扱いに関する方針（データポリシー）v2.0

AI搭載 家計管理ダッシュボード「KAI」

開発・運営者：BODO

問い合わせ窓口：運営者が指定するGoogleフォーム

改定日：2026年5月23日

「KAI — AI搭載 家計管理ダッシュボード」（以下、「本サービス」といいます）では、ユーザーの皆様からお預かりする財務データ、認証情報、およびAIとの対話内容について、技術的なアプローチを最適化し、透明性と機密性を確保した厳格な管理を行っています。以下に、本サービスが採用しているデータ取り扱いの設計方針について説明します。

1. データの暗号化保持と機密性の確保

本サービスでは、通信時および保管時の双方において強力なセキュリティ設計を採用しています。

- **通信の暗号化**：アプリケーションとブラウザ間、および外部API（Supabase、Anthropic、Money Forward等）との全ての通信は、SSL/TLSプロトコルにより完全に暗号化されています。
- **認証情報の暗号化保持**：Money Forward等の自動同期に使用するログイン資格情報（セッション情報・Cookie・パスワード等）は、データベース（Supabase）に保存される際、暗号化アルゴリズムを介して秘匿化されます。これにより、万が一データベース層への不正アクセスが発生した場合や、運営者であっても生データを確認できない仕組みを構築しています。

2. データベース層におけるアクセス制御（Row Level Securityの徹底）

本サービスは、バックエンドプラットフォームとしてSupabaseを採用しており、すべてのデータ格納テーブルに対して**行レベルセキュリティ（RLS: Row Level Security）**を適用しています。

- 認証されたユーザー自身、またはユーザーが明示的に紐付けを行った同一の「世帯（households）」のメンバー以外の第三者が、該当する取引データや予算設定にアクセスすることはシステム構造上、完全に遮断されています。
- マルチテナントアーキテクチャの徹底により、他世帯へのデータ流出リスクを根本から防止しています。

3. AI（Claude API）連携におけるデータ保護とRAGの設計

本サービスは、Anthropic社の提供するClaude API（Sonnet / Haiku）を利用して家計データの自動分類、サマリー生成、予算アドバイス、およびチャット回答の作成を行います。AIモデルへのデータ送信および処理方針は以下の通りです。

- **追加学習の不実施**：商業用API（Claude API）を經由して送信される取引データ、金額、プロンプト等の内容は、Anthropic社による**AIモデルの追加学習や品質向上のためのトレーニングデータとして二次利用されることは一切ありません**。

- **送信データの最小化とマスキング**：AIに自動分類や分析を依頼する際は、口座番号や個人を直接特定可能な情報（氏名等）は送信せず、金額や店舗名・品名などの「家計分析に必要な最小限のテキスト断片」のみに限定して送信します。
- **セキュアなRAG（検索拡張生成）キャッシュ**：表記ゆれ防止や高速化のために構築している埋め込み（Embedding）キャッシュおよびRAGのデータについても、前述のRLSの制御下に置かれ、世帯をまたいで共有または他世帯の検索結果に反映されることはありません。
- **バリデーションの徹底**：AI（Haiku）が定義外のカテゴリ名を返す問題（ハルシネーション）を防止するため、Zodスキーマによる厳格なバリデーションを実施しており、異常なデータはデータベースに保存せず `api_error_logs` に記録してスキップする安全策を取り入れています。

4. Money Forward自動同期（スクレイピング）におけるデータ制限

本サービスが提供するMoney Forwardからの自動同期機能は、ヘッドレスブラウザ（Playwright等）を用いたスクレイピング技術により実現しています。

- **自動同期の仕組み**：Vercel Cron Jobsにより定期的にバックエンドプログラムが起動し、暗号化されて保管されている認証情報を用いて一時的にMoney Forwardへセッション接続します。
- **取得データの限定**：本機能が取得するデータは、ダッシュボードの表示およびAI分析に必要な「口座残高」および「取引履歴（日付・金額・内容）」のみであり、それ以外の個人プロフィールやクレジットカード番号等の不要な情報を取得・蓄積することはありません。

5. コスト管理およびシステムログの厳格運用

本サービスでは、システムの安定稼働およびセキュリティ監視を目的として、以下のログを厳格に管理しています。

- `ai_cost_logs`：AIのモデル別トークン使用量を記録し、過度なリクエストや不正利用の検知に役立てます。
- `api_error_logs`：エラー発生時のシステム状況を記録しますが、ここにはユーザーの生パスワードやセンシティブな取引の個別内容は含まれないよう、マスク処理を徹底しています。

6. 本方針の変更

運営者は、データ取り扱いに関する技術の進歩やセキュリティ要件の変化、関係法令の改定に応じて、本方針を適宜見直し、改定することがあります。本方針を変更する場合、アプリ内の通知またはトップページにて告知します。